PayShield

Contextualisation du risque cyber

Qui est PayShield ?

- Fintech spécialisée paiement mobile — 15 000 transactions/jour
- 1,2 M utilisateurs — données KYC, bancaires, PCI-DSS
- 10 hôtes critiques, 35 vulnérabilités détectées

Pourquoi un scoring contextualisé ?

! Scanners produisent des dizaines de CVE — impossible de tout corriger en même temps

! Le CVSS brut ignore l'exposition réseau, la criticité du système et la nature des données

! Une mauvaise priorité = ressources gaspillées, vraie menace non traitée

35
Vulnérabilités détectées

10
Hôtes analysés

1,2M
Utilisateurs exposés

PCI-DSS
Conformité requise

Notre formule SRC

Score de Risque Contextuel — au-delà du CVSS

$$SRC = CVSS \times W_Exposition \times W_Criticité \times W_Données \ / \ SRC_max \times 10$$

Exposition réseau	
Internet	×2,0
DMZ	×1,5
Interne	×1,0

Vecteur d'attaque :
Internet = accessible
depuis n'importe où

Criticité système	
Critique	×2,0
Élevée	×1,5
Moyenne	×1,0
Faible	×0,5

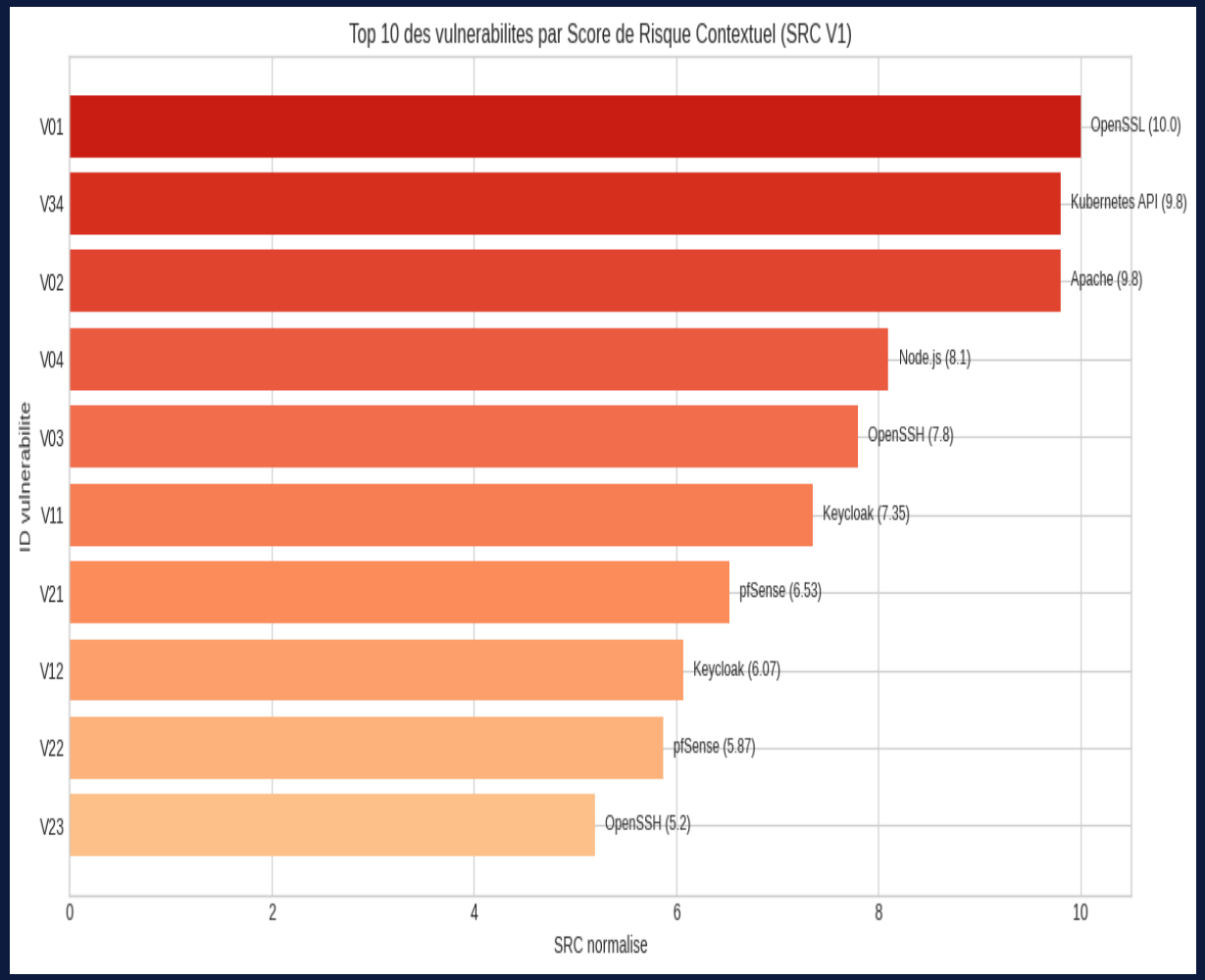
Importance métier :
BDD paiement ≠
env. de dev

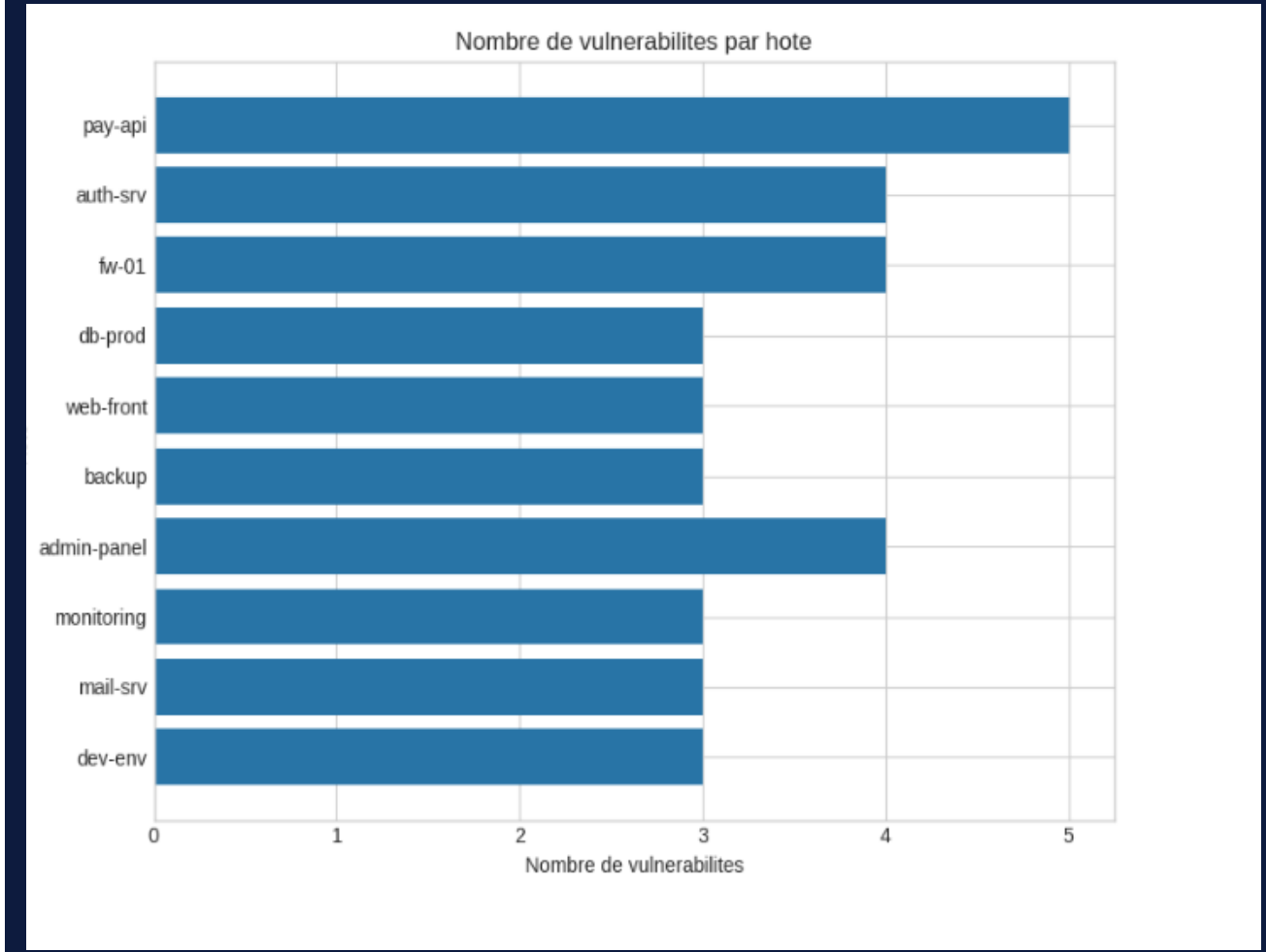
Sensibilité données	
Sensible	×1,5
Interne	×1,0
Public	×0,5

Nature des données :
KYC & transactions ≠
données publiques

Top 10 — Résultats SRC

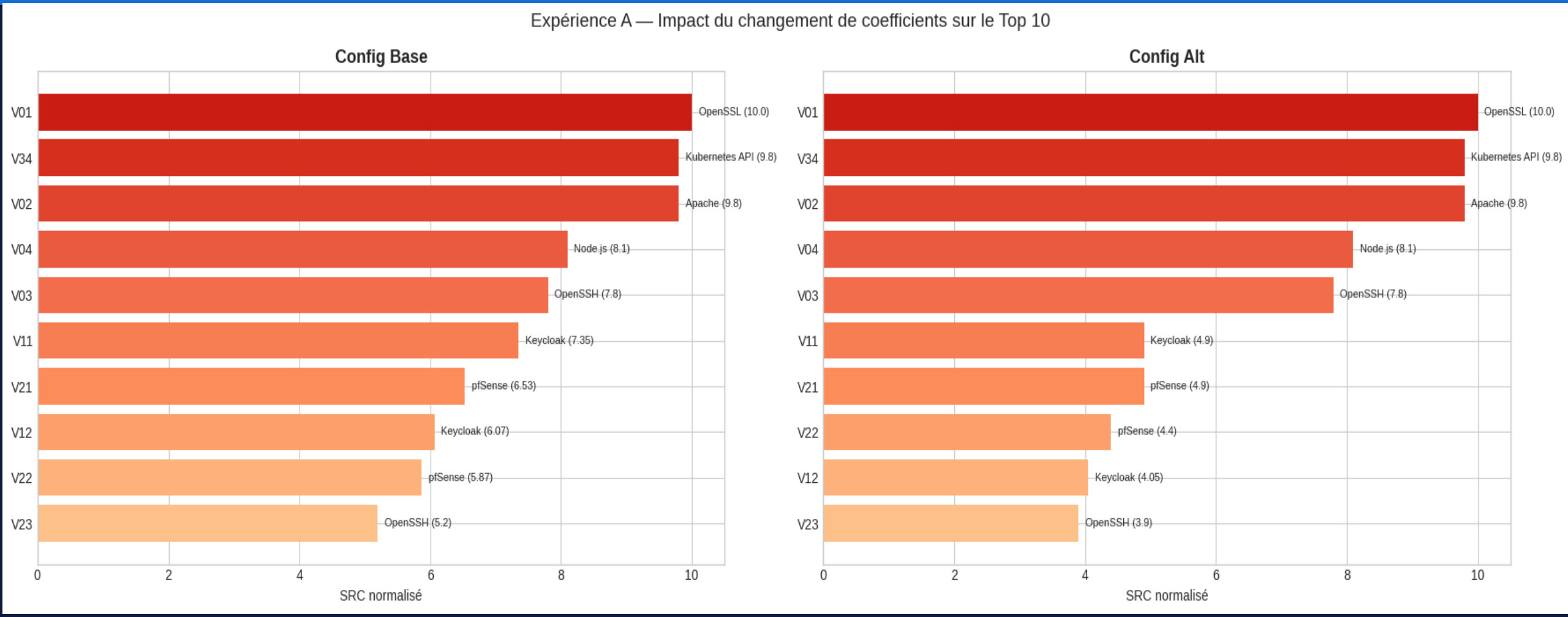
Classement contextualisé des vulnérabilités PayShield





Pourquoi le CVSS seul ne suffit pas

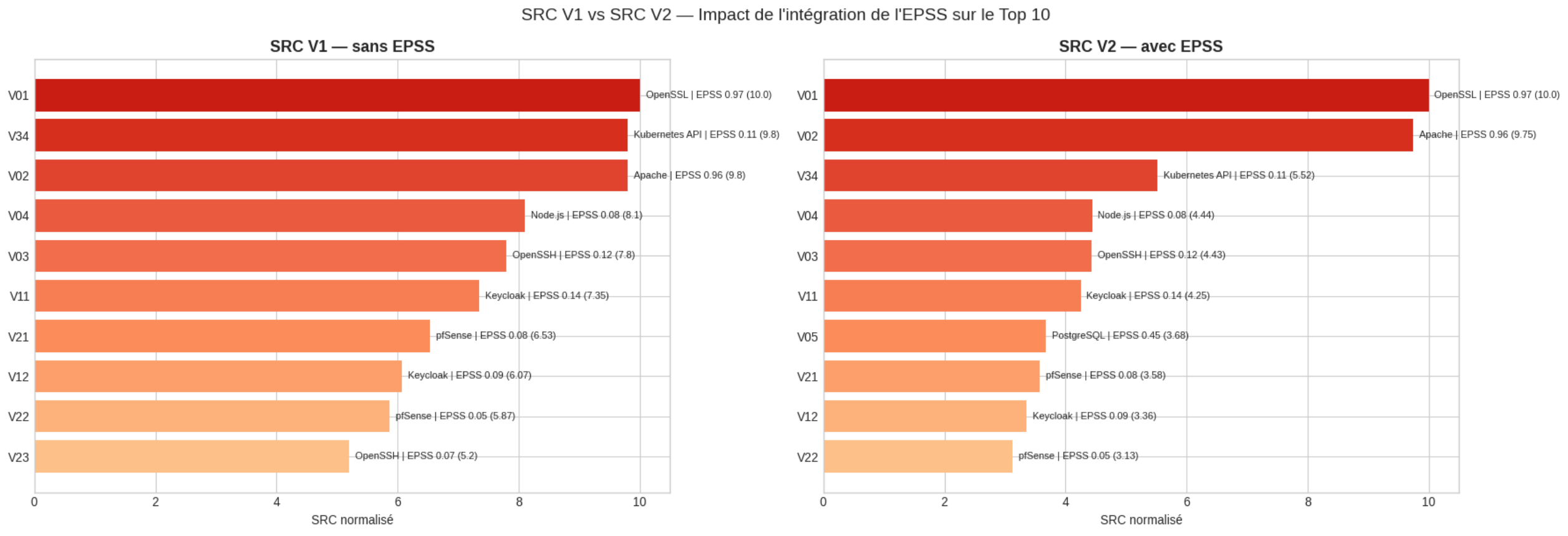
Expérience A — Comparaison Config Base vs Config Alt



Notre amélioration : SRC V2

Intégration EPSS — de la gravité théorique au risque réel exploitable

SRC V2 = CVSS × W_Expo × W_Crit × W_Données × (1 + EPSS)



Plan J+7 pour PayShield

3 actions immédiates — responsable + impact si non fait